

Threat Modeling

SAPA IPB - Kelompok 04

Fadia Syakira Mustaniroh	G6401231005
Indriyani Khairan Nisa	G6401231044
Muthia Khansa	G6401231123

1. Identifikasi Aset Kritis

1. Data pribadi mahasiswa (NIM, nama, alamat, data akademik) :
Sensitif, memerlukan perlindungan enkripsi *end-to-end*.
2. Dokumen persuratan digital: Surat keputusan, transkrip, dsb. :
Membutuhkan integritas dan *non-repudiation*.
3. Private key / key material (Signature & Enkripsi) :
Kunci kriptografi penting, disimpan di KMS/HSM untuk mencegah pencurian.
4. Session tokens (JWT & Refresh Token) :
Digunakan untuk otorisasi akses, perlu rotasi dan *expiration* singkat.
5. Audit logs & Accounting records :
Rekaman tindakan sensitif, harus *immutable* untuk akuntabilitas.

2. Aktor dan Ancaman Utama

1. User Terautentikasi; Mahasiswa, Staff, Admin :
Ancaman internal (salah konfigurasi/salah akses) dan *insider threat*.
2. Penyerang Eksternal: Pencuri kredensial, MITM :
Ancaman umum seperti *phishing*, *malware*, dan serangan pada jalur komunikasi.
3. Sistem Terintegrasi: Layanan Notifikasi, API Klien :
Titik lemah pada integrasi pihak ketiga atau layanan internal yang terkompromi.

3. Alur Data Penting

1. Autentikasi: Login → Validasi → Token Issuance:
Proses verifikasi identitas pengguna.
2. Otorisasi: Request Akses → Decrypt Data Berdasarkan Role:
Memastikan hak akses sesuai peran (RBAC).
3. Integritas: Generate Dokumen → Sign → Store Hash:
Memastikan dokumen tidak dimodifikasi setelah dibuat.
4. Akuntabilitas: Audit logging pada setiap aksi sensitif:
Pencatatan aktivitas untuk jejak audit.

4. Matriks Mitigasi Ancaman (STRIDE)

Kategori	Aset Terdampak	Kontrol Keamanan (Mitigasi)
<i>Spoofing</i>	Kredensial, Session Tokens	[Authentication] Penerapan autentikasi kuat (Hashing) dan pengendalian akses login.
<i>Tampering</i>	Dokumen, Data Mahasiswa	[Integritas] Digital signature dan hash verifikasi dokumen
<i>Repudiation</i>	Audit Log, Aksi User	[Accounting] Pencatatan audit log detail dengan digital signature.
<i>Information Disclosure</i>	Data Pribadi, Private Key	[Enkripsi] Field-level Encryption, TLS, serta Perlindungan Kunci Privat (KMS/HSM).
<i>Elevation of Privilege</i>	Role/Scope, Endpoint Sistem	[Authorization] Kontrol otorisasi berbasis peran (RBAC/ABAC) dan validasi izin ketat.